

Security Overview

sharkshare platform — yornik.eu / fedishark.eu estate

Report date	2026-09-28
Assessment type	Non-intrusive external probes + GitOps repository review
Requested by	Platform owner (yornik@gmail.com)
Authorization	Owner-authorized assessment of owned domains and repository
Sources	Live HTTP/TLS/DNS probes + sharkshare-gitops docs and manifests
Prepared with	Claude Code
Classification	Confidential — internal

NOTE: This overview uses read-only external observations and a review of the public GitOps repository. It did not run intrusive tests. It did not attempt exploitation, brute-force or authentication bypass. It reports the design of the controls and the external state of each service on the date above. The companion file 2026-09-28-yornik_eu.pdf covers the yornik.eu endpoint in detail.

1. Executive summary

The sharkshare platform is a self-hosted homelab. It runs on a 4-node Talos Kubernetes cluster. ArgoCD reconciles about 40 applications from the sharkshare-gitops repository. The platform serves 15 public HTTPS domains.

The security design is strong for a homelab. Traffic enters through 2 hardened Hetzner edge hosts. It tunnels over a Tailscale mesh. Traefik terminates TLS with Let's Encrypt. A shared middleware sets HSTS with preload, rate limiting and a fail2ban filter. Secrets are encrypted with SOPS and age. Every change passes 7 CI checks before merge.

The external probes found every administrative and application login gated by authentication. The review found no high severity issue. It found medium, low and informational items. The main theme is exposure: several high-value services are reachable from the whole internet. The second theme is header coverage: Content-Security-Policy is set per application, not estate-wide.

Findings by severity

Severity	Count
High	0
Medium	1
Low	4
Informational	3

2. Architecture in brief

The data below comes from the sharkshare-gitops technical overview.

Layer	Detail
Edge	2 Hetzner hosts (Nuremberg + Helsinki). HAProxy L4 TCP with PROXY v2. Tailscale. fail2ban.
Transport	Tailscale mesh from the edge hosts to the home cluster. TLS ends at Traefik (Let's Encrypt HTTP-01).
Compute	4 Intel N150 nodes, Talos Linux, 128 GiB total. 3 control-plane + 1 worker, all schedulable.
Data	3 CloudNativePG clusters (shared / OpenProject / GitLab), 3-instance HA. WAL archive to Hetzner Object Storage.
Storage	TrueNAS SCALE. NFS + iSCSI + SMB. Postgres on iSCSI with sync=standard for real fsync durability.
Observability	kube-prometheus-stack + Grafana. Alloy to Loki, 60-day retention.
Delivery	ArgoCD app-of-apps. GitHub webhook triggers sync. prune + selfHeal enforce git state.
Secrets	SOPS + age. KSOPS decrypts in the ArgoCD repo-server. No plaintext secret in git.

3. Public attack surface

The table lists every public domain from the repository. The probe columns show the external result on 2026-09-28. "Auth" shows how the service protects itself. "Exposure" shows who can reach the login.

Domain	Service	Probe	Auth	Exposure
yornik.eu	Professional site	200, CSP+HSTS	Static	Public (by design)
fedishark.eu	Landing site	200, HSTS	Static	Public (by design)
pub.fedishark.eu	GoToSocial (Fediverse)	200, CSP+HSTS	App login	Public (private instance)
secrets.yornik.eu	PrivateBin	200, CSP+HSTS	None (paste)	Public (by design)
omni.fedishark.eu	OmniTools	200, HSTS	None (client-side)	Public (by design)
grafana.fedishark.eu	Grafana	302 to login	App login	Internet-wide
argocd.fedishark.eu	ArgoCD UI + webhook	200, CSP+HSTS	App login + fail2ban	Internet-wide (admin)
asf.fedishark.eu	ArchiSteamFarm	200, HSTS	IPCPassword + fail2ban	Internet-wide (admin)
jelly.yornik.eu	Jellyfin	302, HSTS	App login	Internet-wide
passwords.yornik.eu	Vaultwarden	200, CSP+HSTS	App login	Internet-wide (secrets)
todo.yornik.eu	Vikunja	200, HSTS	App login	Internet-wide
plan.yornik.eu	OpenProject	302 to /login	App login	Internet-wide
git.yornik.eu	GitLab CE	302 to sign_in	App login	Internet-wide
registry.git.yornik.eu	GitLab registry	200 (API root)	Token	Internet-wide
bokings-driessen.party	soiree planner	200, HSTS, noindex	App login	Internet-wide

NOTE: "Internet-wide" means the login page is reachable from any IP address. The service still needs a valid credential. The probes did not test the credentials.

4. Estate-wide controls that work well

Control	Evidence
Shared security headers	Traefik middleware sets HSTS (preload), nosniff, frameDeny and referrer no-referrer.
Rate limiting	Traefik rate-limit middleware: 300 average, 600 burst.
fail2ban at the edge	A fail2ban middleware is attached to 12 IngressRoutes. ArgoCD and ASF have their own filters.
Encrypted secrets	SOPS + age. KSOPS decrypts in-cluster. No plaintext secret in git. ASF IPCPassword is a SOPS secret.
PR-gated changes	7 CI checks per PR: yamllint, signed security.txt, KSOPS hash guard, helm template, values render, kubeconform
Supply-chain guard	KSOPS pinned-hash check blocks a version bump with a stale checksum.
Signed disclosure	The published security.txt is PGP-signed and CI validates the signature.
Modern TLS	TLS 1.3 with Let's Encrypt certificates. CAA records limit issuance.
Backups	Continuous WAL archive plus scheduled base backups to Hetzner Object Storage for all 3 Postgres clusters.

5. Observations

O-01 **MEDIUM** High-value services reachable from the whole internet

Observation. The admin and secret-holding services accept connections from any IP address. This includes Vaultwarden (passwords.yornik.eu), ArgoCD (argocd.fedishark.eu), Grafana, GitLab and ArchiSteamFarm. Each service enforces its own login, and fail2ban slows brute-force. The risk is a flaw in one application, or a stolen credential, giving a remote attacker a direct path.

Recommendation. Put the admin interfaces behind the Tailscale mesh, or behind an IP allowlist, so the login is not reachable from the whole internet. Keep only the services that need public access open. Enable multi-factor authentication on Vaultwarden, GitLab and Grafana. Set a lockout and a strong master password on Vaultwarden.

O-02 **LOW** Content-Security-Policy is set per application, not estate-wide

Observation. The shared security-headers middleware does not set a Content-Security-Policy. Some applications set their own (yornik.eu, PrivateBin, GoToSocial, ArgoCD, Vaultwarden). Others send no CSP (Grafana, Jellyfin, Vikunja, OmniTools, the landing site, ArchiSteamFarm). Without a CSP a cross-site scripting flaw has fewer limits.

Recommendation. Add a default CSP to the shared middleware, then relax it per application where needed. Start in report-only mode to find breakage before you enforce.

O-03 **INFO** Deprecated X-XSS-Protection header set estate-wide

Observation. The shared middleware sets browserXssFilter. This produces the x-xss-protection header on every application. Modern browsers ignore it. In old browsers it can add a side effect.

Recommendation. Remove browserXssFilter from the shared middleware. The CSP from O-02 is the correct control.

O-04 **LOW** security.txt discloses the full subdomain inventory

Observation. The signed security.txt lists Canonical URLs for many hosts, including passwords., secrets., argocd. and grafana. This gives an attacker a map of the estate without any scanning.

Recommendation. Keep only the entries a researcher needs. Move the full host list out of the public file.

O-05 **LOW** Email authentication is incomplete

Observation. DMARC is v=DMARC1; p=quarantine; with no aggregate report address (rua). No DKIM record was found at common selectors. SPF ends with a soft fail (~all). Mail sends through Amazon SES.

Recommendation. Add an rua address. Confirm SES DKIM signing and alignment. Move to p=reject and -all when reports are clean.

O-06 **INFO** Software and version disclosure in Server headers

Observation. Server headers name the software and sometimes the version: nginx/1.31.1, nginx/1.29.1, gotosocial, Kestrel, Rocket. This helps an attacker match known issues to a service.

Recommendation. Hide the version where the reverse proxy allows it. Set server_tokens off in nginx. This is a small gain; patching stays the main control.

O-07 **LOW** Single points of failure for availability

Observation. The repository records one power feed, one internet uplink and one shared NAS for stateful workloads. The owner records these as accepted homelab tradeoffs. They are an availability risk, not a breach risk.

Recommendation. Accept the risk for a homelab, or add an independent uplink with its own battery for real failover. Keep the off-site backups current so a storage loss is recoverable.

6. Prioritized recommendations

1. Move the admin interfaces (ArgoCD, Grafana, ArchiSteamFarm) behind Tailscale or an IP allowlist. (O-01)
2. Enable multi-factor authentication on Vaultwarden, GitLab and Grafana. (O-01)
3. Add a default Content-Security-Policy to the shared middleware in report-only mode, then enforce. (O-02)
4. Add a DMARC rua address. Confirm SES DKIM. Move to p=reject and -all when reports are clean. (O-05)
5. Trim the subdomain list in security.txt to the entries a researcher needs. (O-04)
6. Remove browserXssFilter and hide server versions. (O-03, O-06)
7. Run the active phases (nmap, testssl.sh, nuclei, OWASP ZAP) against the owned hosts in a planned window. See the tool table in the companion yornik.eu report.

7. Method and scope

The assessment combined two sources. The first source is live external probes of each public domain: HTTP status and headers, TLS handshake, and DNS records over DNS-over-HTTPS. The second source is a read-only review of the sharkshere-gitops repository: the technical overview, the Traefik middleware, the IngressRoutes and the CI configuration.

The probes were read-only. The assessment did not log in to any service. It did not scan ports. It did not test input fields. It did not read any encrypted secret. The severity of each observation reflects external impact. It is not a CVSS score.

8. Appendix — probe evidence

Collected 2026-09-28 with curl and DNS-over-HTTPS. One line per host.

```
yornik.eu 200 nginx/1.31.1 CSP=yes HSTS=yes
fedishark.eu 200 nginx/1.31.1 CSP=no HSTS=yes (landing page)
pub.fedishark.eu 200 gotosocial CSP=yes HSTS=yes (private instance)
grafana.fedishark.eu 302 -> login CSP=no HSTS=yes
argocd.fedishark.eu 200 Argo CD CSP=yes HSTS=yes (fail2ban)
asf.fedishark.eu 200 ASF CSP=no HSTS=yes (IPCPassword + fail2ban)
omni.fedishark.eu 200 nginx/1.29.1 CSP=no HSTS=yes (OmniTools)
jelly.yornik.eu 302 Kestrel CSP=no HSTS=yes (Jellyfin)
passwords.yornik.eu 200 Rocket CSP=yes HSTS=yes (Vaultwarden)
todo.yornik.eu 200 Vikunja CSP=no HSTS=yes
secrets.yornik.eu 200 nginx CSP=yes HSTS=yes (PrivateBin)
plan.yornik.eu 302 -> /login HSTS=yes (OpenProject)
git.yornik.eu 302 -> /users/sign_in HSTS=yes (GitLab CE)
registry.git.yornik.eu 200 (registry API root) HSTS=yes
bokings-driessen.party 200 HSTS=yes X-Robots-Tag: noindex, nofollow (soiree)
```

End of overview. This reflects the external state and the repository content on 2026-09-28. A later change can change the result.